

Human-AI Collaboration in Compliance Automation: Designing an Agentic Knowledge Base for AI Governance

Simon Jarvers
Technical University of Munich
simon.jarvers@tum.de

Carolin Röthemeier
Technical University of Munich
carolin.roethemeier@tum.de

Orestis Papakyriakopoulos
Technical University of Munich
orestis.p@tum.de

Holger Wittges
Technical University of Munich
holger.wittges@tum.de

Abstract

AI governance work draws on a living body of organizational knowledge, policies, and system facts that drift and go stale as organizational and regulatory contexts change. For resource-constrained organizations under the EU AI Act and related standards, maintaining this knowledge consumes scarce compliance capacity. We applied a pattern drawn from practice, in which an LLM agent maintains a structured, citation-anchored knowledge base for AI governance. Through a Design Science Research study at an AI startup, we apply the artifact to two ISO management system standards. The artifact separates a human-authoritative source layer from an agent-moderated knowledge layer in the company's internal governance work processes. We abstract two design principles, human authority over agent moderation and traceability, which demonstrate how to responsibly leverage advancing AI capabilities for human-agent collaboration in regulated compliance settings.

Keywords: AI Governance, EU AI Act, ISO/IEC 42001, Design Science Research, Agentic Knowledge Base, AI Agents

1. Introduction

The EU AI Act (Regulation 2024/1689) places extensive governance obligations on providers and deployers of high-risk AI systems within the EU, spanning risk management, data governance, technical documentation, logging, transparency, and human oversight. These rarely stand alone as an organization must sustain them alongside overlapping information-security and data-protection requirements.

The requirements impact resource-constrained small and medium-sized enterprises (SMEs) disproportionately, since they must fulfill the same obligations as larger firms, often without dedicated legal or compliance functions (Cors & Thiébaut, 2025). As of mid 2026, the AI Act is not yet fully in force, but ISO/IEC 42001¹ already mirrors much of its content and offers a certifiable management system route that companies are implementing to prepare for the upcoming regulation. The governance challenge compounds because the systems under regulation are themselves built with increasing AI assistance. 84% of developers now use AI tools in their development workflow, and roughly a third already use AI agents for coding tasks at work.² AI systems subject to governance obligations are modified and deployed at a cadence that manual compliance processes cannot sustain. Each development sprint widens the distance between the system as built and the system as governed, and organizations that fail to close this gap risk becoming compliant on paper while non-compliant in the systems they actually operate. Closing it calls for governance infrastructure that runs at development velocity, which means repurposing the agentic capabilities that produced the pace problem for the compliance work itself. Delegating governance work to AI agents introduces a tension that the regulation itself anticipates. The EU AI Act mandates human oversight of AI systems (Art. 14), but the more compliance knowledge work an agent performs, the greater the risk of automation bias and eroding human agency,

¹ISO/IEC 42001:2023 is not a harmonized European Standard and so is not, by itself, sufficient for high-risk EU AI Act compliance (see <https://www.iso.org/home/insights-news/resources/iso-42001-explained-what-it-is.html>). The study's other standard, ISO/IEC 27001:2022, governs information security.

²Stack Overflow Developer Survey 2025, N > 49000 respondents. <https://survey.stackoverflow.co/2025/>.

precisely the failure modes the oversight requirement targets (Parasuraman & Riley, 1997). Principles alone do not yield responsible AI without processes and tooling to enact them, and structural reasons explain why they fail to reach day-to-day practice (Mittelstadt, 2019; Schiff et al., 2021). Layered governance models locate the work at the level of concrete organizational workflows (Mäntymäki et al., 2022), and the artifact operationalizes that layer as governance infrastructure a small team can actually run. What the literature leaves open is how governance knowledge can be sustained coherently as organizations and regulatory contexts change, and how agents and humans should share that work while preserving the authority that regulation demands. We treat compliance as the demonstrable conformity of the organization’s record to its obligations, and AI governance as the broader organizational function that maintains that conformity while steering AI systems responsibly.

Compliance work depends on a coherent body of policies, registers, and audit knowledge, but this substrate degrades naturally as documents drift, version histories grow unreliable, and inconsistencies creep in. Small governance teams lack the capacity to reconstruct this picture on demand. Andrej Karpathy’s “LLM Wiki” proposes that an LLM incrementally build and maintain a persistent, interlinked set of Markdown pages that compound and update as each new source arrives (Karpathy, 2026). We project this pattern to a compliance use case and term the resulting artifact an *agentic knowledge base*: the agent builds and maintains a structured, citation-anchored knowledge layer over a corpus of human-approved, authoritative source documents, while the authoritative record above it stays fixed and beyond the agent’s reach. The pattern circulates as gray practitioner material; no peer-reviewed study has designed or evaluated it in a governance setting, where auditability and traceability are more demanding. This gap motivates the question of our study: **How can an agentic knowledge base be designed to support auditable, traceable AI governance work in a resource-constrained organization?** We address it through Design Science Research at a single ISO-certified AI startup: we design the artifact, implement it in operational governance work, evaluate it across two ISO/IEC management-system standards, and abstract two design principles from the design process. We designed the compliance automation to be limited. The agent automates the maintenance and cross-checking of governance knowledge, while decision power stays with the human.

2. Related Work

This study connects three areas of research: how AI-generated knowledge structures are built and kept current, how AI supports regulatory compliance, and how humans and machines share work under hybrid intelligence. Each stream supplies part of what an agentic knowledge base for governance needs, but none has examined how to keep such a base auditable and traceable while a human retains authority over it.

Constructing and maintaining AI-generated knowledge. The first strand concerns how LLMs build knowledge structures and keep them current, the mechanism our artifact repurposes for governance. Work here has concentrated on one-shot or session-scoped construction. Co-STORM curates a session-scoped, human-in-the-loop mind map through simulated multi-perspective inquiry (Jiang et al., 2024), while graph-based approaches build entity-relationship indices from a fixed corpus at build time (Edge et al., 2024; Zhang & Soh, 2024). Keeping such structures current as their sources change is an active concern: temporal and agent-memory architectures address incremental updating and stale-knowledge removal (Rasmussen et al., 2025), and continual-learning research frames maintenance over a living corpus as an open challenge. A related line studies the governance of generative-AI-mediated knowledge capture, deriving principles to contain risks such as hallucination and goal drift (O’Sullivan et al., 2026). These systems generate and refresh knowledge, but none is built for the auditability and traceability that a compliance setting demands, which the next strand takes up.

AI-assisted regulatory compliance. AI support for regulatory compliance has developed along several lines. On the regulatory-text side, Galli et al. (2026) combine an LLM with a knowledge graph pipeline to extract and structure the prescriptive obligations of the EU AI Act, building on similar expert-validated legal extraction across the GDPR, DSA, and the AI Act (Dal Pont et al., 2025). On the system-documentation side, Sovrano et al. (2025) automate the review of EU AI Act Annex IV technical documentation for individual high-risk systems. Zieliński et al. (2026) decomposes governance documents into atomic obligations mapped to testable system-specific rules, flagging unverifiable obligations for human resolution, while Axelsen et al. (2025) orchestrates autonomous multi-agent workflows for financial crime compliance at the organizational level. A longer-standing tradition encodes regulatory obligations as executable rules for automated compliance checking (Governatori, 2015). Marino and Lane (2026) push this ambition throughout

the system life cycle, arguing that compliance must become computational: algorithms that continuously steer an AI system toward compliance under changing conditions, for which they propose design goals and a benchmark. Methodologically, insider design-science studies have produced compliance artifacts within a single organization, including an n=1 study of GDPR compliance in a continuous-integration setting (Li et al., 2022).

Human-AI collaboration and hybrid intelligence.

Hybrid intelligence describes socio-technical systems that combine the complementary strengths of human and machine to reach outcomes neither achieves alone, achieved through deliberate task allocation and continuous co-evolution where AI augments human work instead of supplanting it (Dellermann et al., 2019). Parasuraman and Riley (1997) distinguish misuse, the over-reliance that produces monitoring failures and automation bias, from disuse as well as the neglect that follows frequent false alarms. The subsequent literature describes that effective reliance depends on trust calibrated to the system's actual competence (Lee & See, 2004). From an organizational standpoint, the division of work between human and agent can be read as an allocation of decision rights over knowledge, which knowledge-governance scholarship treats as something deliberately assigned rather than left implicit (Foss et al., 2010; Grandori, 2001). Each of these efforts targets a slice of the compliance lifecycle, extraction, documentation review, or workflow orchestration, in isolation. What remains untested is whether an agent can sustain the connective tissue between them: a living, citable knowledge layer that an organization's entire governance practice can be run from.

3. Method

This study follows the Design Science Research (DSR) paradigm (Hevner, 2007; Peffers et al., 2007). The central contribution is a designed artifact, and the transferable design knowledge abstracted from building and evaluating it in a genuine governance setting, which DSR is expressly positioned to produce. Following Hevner (2007), the study instantiates three research cycles. The *Relevance Cycle* is grounded in a startup that develops AI-powered solutions for training and task execution in industrial settings. It employs approximately fifteen people and is certified under ISO/IEC 27001 and ISO/IEC 42001 and is preparing proactively for EU AI Act compliance. The first author is the organization's AI Governance Officer and built, used, and maintained the artifact. The second author and

further co-Authors are independent of the organization. Requirements included in the design are detailed in Section 4.1. The *Rigor Cycle* draws on Karpathy's practitioner LLM Wiki pattern as the design kernel for an agentic knowledge base in compliance work (Karpathy, 2026). Grounding the kernel in a practitioner artifact is deliberate: design science admits practice as a source of design knowledge alongside theory (Hevner, 2007), and the kernel's rigor comes from the theory that constrains it and the evaluation that tests it. Its anchors are hybrid intelligence as the design goal (Dellermann et al., 2019) and automation misuse and bias as the design constraint (Lee & See, 2004; Parasuraman & Riley, 1997), with knowledge governance supplying the vocabulary of decision rights over organizational knowledge (Foss et al., 2010; Grandori, 2001). The design principles and reflective findings are developed in Section 6. The *Design Cycle* iterates between building and evaluating the artifact. The schema and layer structure were designed to fulfill the objectives defined in Section 4.1. The first cycle ingested the ISO/IEC 42001 management-system corpus and was evaluated formatively, being conducted during the process to guide ongoing refinement: a qualitative assessment with internal stakeholders, guided by reflections on the research journal kept throughout development, exposed structural weaknesses whose corrections are reported in Section 5.1. The second cycle extended the refined artifact to the ISO/IEC 27001 corpus. Because artifact value depends on operation in a genuine setting rather than laboratory conditions, the Framework for Evaluation in Design Science (FEDS) (Venable et al., 2016) identifies naturalistic evaluation as the appropriate strategy for both cycles, meaning that the artifact is evaluated in a real, unmodified environment with actual users and data rather than an artificial or controlled lab setting. What differs between the two cycles is FEDS's separate purpose dimension, formative in the first cycle and summative-leaning in the second. The summative-leaning evaluation of the mature artifact through its use in real governance work is reported in Section 5. It also yielded formative insights, surfaced through an external focus-group, nine people consisting of subject-matter experts discussion and an expert interview with the company's Chief Technology Officer (CTO), that scope a prospective third cycle set out as a design agenda in Section 7.

The insider position of the first author is a main risk to validity, since one person built, operated, and evaluated the artifact. The threat applies unevenly across the two modes. The first evaluation was performed by two internal stakeholders, the first author and the CTO, who reviewed the research journal together and

identified recurring issues reflectively without applying a formal coding method. The second evaluation drew on independent co-authors who reviewed the contradiction flags and the knowledge base separately from the first author, a CTO interview in which the CTO had no incentive to endorse an artifact that did not serve the company, and an external focus group. The organization passed its ISO/IEC certification audits with no non-conformities, which verifies that the management system operates as intended and signals that the artifact serves its purpose. Since audits evaluate the management system against the standards' requirements rather than the artifact itself, we treat this as demonstration context. Generalization runs through design-knowledge abstraction rather than statistical inference; the scope of that claim is addressed in Section 8.

4. Artifact

4.1. Objectives

The design objectives (DO) were set during the project's ideation phase, in discussions with internal organization stakeholders and independent external experts from the author's professional network. They build on prior compliance experience and on published industry best practices for implementing the EU AI Act³ and related industry standards. Four objectives resulted:

DO1 Preserve human authority and auditability: the artifact must remain a derived, never-authoritative layer over a human-owned record, with every claim traceable to a versioned source.

DO2 Reduce the effort of administrative and cross-document governance work, such as audit preparation, management review, and policy cross-checking, so that verification work that was structurally possible but not economically feasible becomes routine.

DO3 Surface drift, contradiction, and staleness as advisory, non-blocking signals the governance officer can act on.

DO4 Be adoptable and maintainable by a single resource-constrained governance function, and transferable across governance frameworks.

The evaluation returns to these objectives to assess how far the artifact meets them in use.

³e.g., AppliedAI Initiative's White Paper on "AI Act Governance: Best Practices for Implementing the EU AI Act."

4.2. Design and development

The artifact is a file-based knowledge base whose structure is fixed by a single schema document, which will be introduced in this chapter. The schema defines three folders. The first `source` folder holds the authoritative source documents in preprocessed form and is read-only to the knowledge. The `knowledge` folder holds the agent-maintained pages, interlinked and indexed, that synthesize and cross-reference those sources. The `housekeeping` folder contains an operation log and two flag folders for open and closed flags, through which the agent raises issues for human decision. The schema also fixes the page format, the citation rules, and the workflows that operate on these three named folders.

Two layers run through this structure. The human-authoritative layer is the body of source documents that the organization owns and approves. The agent-maintained layer is the derived knowledge base that the agent builds and revises over time. The `source` folder is where the two connect. A source crosses into the knowledge base only when the governance officer preprocesses and deposits it without modification by the agent itself. Preprocessing renders Word, Excel, and PDF files into Markdown, CSV, and TXT. The step is mechanical, but it fixes the boundary of the authoritative layer, because the governance officer controls what becomes a source. This makes sources not limited to formal compliance documents. The layer also contains the customer-facing website, the public trust center, and supplier and customer documentation, so the knowledge base answers questions that the compliance corpus alone cannot. The agent operates the knowledge base through workflows that correspond to three lifecycle stages, shown in Figure 1. At the setup, an ingestion workflow reads each source and writes the knowledge base pages that synthesize it, building the initial set of pages and index. In use, a query workflow retrieves the relevant pages to answer a governance question with citations to the source. Under maintenance, an updated file re-uploaded to `source` triggers a re-ingestion workflow that locates and revises the affected pages and updates their citations. Here, a lint workflow audits the knowledge base for contradictions, stale claims and orphaned references. Every workflow records its actions in the operation log and raises flags in `housekeeping` whenever human judgment is required. The agent maintains the derived knowledge layer, while the customer-facing and verification-facing compliance documents remain human-reviewed and approved. Three mechanisms maintain the derived layer's fidelity without granting it

authority. The authoritative sources are read-only, so the agent cannot alter the record it draws on. Every knowledge base claim carries a versioned citation to its source, so the derived layer stays checkable against the authority and provenance survives document updates. When the agent meets a contradiction, a stale claim, or an ambiguity it cannot resolve, it raises an advisory flag and waits for the human to take action. Section 6 abstracts this separation into the two design principles that form the study's design-knowledge contribution.

4.3. Demonstration

The artifact was built and used for operational governance work at the case organization described in Section 3. In their setup, they ingested roughly 30 ISO/IEC 42001 management-system documents, spanning policies, procedures, and registers, along with previous audit reports and management reviews. Additionally, around 20 heterogeneous adjacent sources were ingested, such as public company website details, customer-facing trust center pages, and supplier and customer information. The first cycle produced the initial knowledge base, its index, and the first set of contradiction flags. In use, the artifact supported three kinds of tasks. It was requested to discuss changes to the management system arising from non-conformities and opportunities for improvement logged in previous audit cycles, including newly emerging risks to the company's risk management system. It was queried to work through changes to the AI system and the organizational context, such as the deployment of new foundational base models and the redistribution of responsibilities after new hires. Moreover, it was used to prepare internal and external audits and management reviews from the logged changes to the management system. Each change to the authoritative layer was an updated source and triggered the maintenance workflow in the agentic knowledge base layer, which revised the affected pages and raised flags for arbitration.

5. Evaluation

The evaluation was carried out in two modes. Each strand returns to the objectives of Section 4.1. Administrative efficiency tests DO2. Contradiction-flag analysis tests DO3. Cross-standard transfer tests the transferability of DO4, while the trade-off analysis tests the adoptability of DO4. DO1 differs because human authority over the records is enforced architecturally, rather than evaluated as a behavior. A formative evaluation of the first design cycle identified structural weaknesses and fed refinements back into the artifact before it was extended to a second standard. It was

conducted qualitatively with internal stakeholders and supported by reflections on the research journal kept during development and use of the artifact. The summative-leaning evaluation that follows assessed the mature artifact through its operation in real governance work, covering administrative efficiency, contradiction detection, and artifact trade-offs. A focus-group discussion with external subject-matter experts and an expert interview with the company's CTO are drawn on for the trade-off analysis and inform the design agenda projected in Section 7. The evaluation establishes feasibility in one setting, and does not establish effectiveness across organizations. The efficiency findings rest on worked examples without a controlled baseline.

5.1. Formative evaluation and cross-standard transfer

The first cycle, built over the ISO/IEC 42001 corpus, exposed three structural weaknesses. The operation log and the flags had initially lived inside the knowledge base, mixing the human-interaction queue with derived content. Moving them into a dedicated housekeeping folder separated interaction state from the knowledge layer. Templates for pages, flags, and log entries were introduced to keep outputs consistent across operations and operators. The single ingestion workflow was split into first-ingestion and re-ingestion variants: a new source is synthesized from scratch, while an updated source requires locating and revising prior claims and their citations. All three corrections were applied before the second cycle. The second cycle extended the refined artifact to the information security management system, testing whether the design generalizes beyond the standard it was built for. The schema, layer structure, and workflows carried the ISO/IEC 27001 corpus without further structural change; the artifact ingested, queried, and maintained the new documentation in the same manner. The extension is a generalization step, not a comparison of the two standards. That a knowledge base designed for AI management also serves information-security management warrants the related-standards clause in the research question, though the evidence is bounded.

5.2. Administrative efficiency

Much governance work is mandatory administration that consumes resources without producing substantive value. Two recurring tasks illustrate how the artifact shifts that burden. In the version-consistency check, each of the roughly thirty management-system documents must carry a consistent version across its

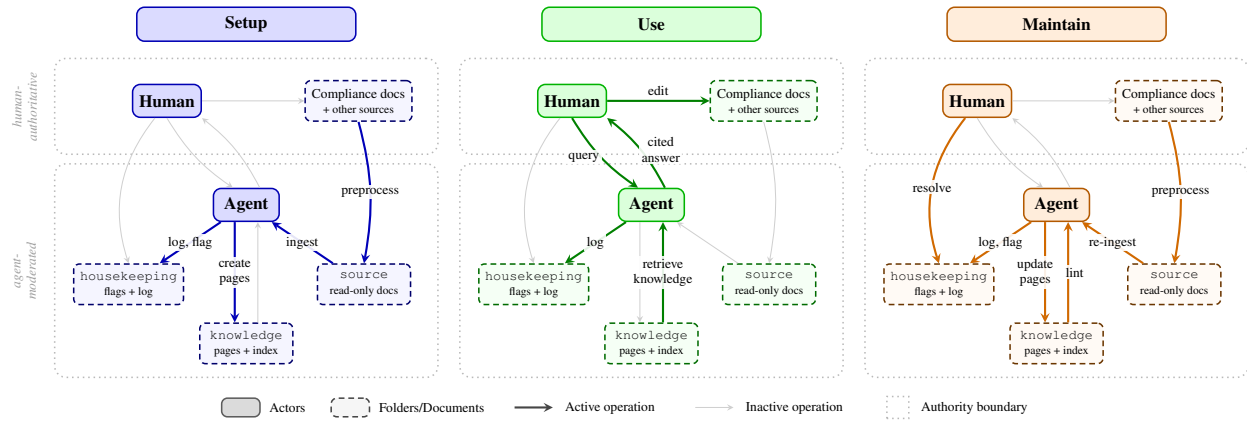


Figure 1. The agentic knowledge base architecture, a human-authoritative source layer over an agent-moderated knowledge layer, across its three lifecycle stages: *Setup* ingests preprocessed authoritative sources into the knowledge base and checks for consistency. *Use* answers queries based on the ingested knowledge with citations to source. *Maintain* re-ingests updated sources, re-checks consistency, and routes flags to the governance officer for arbitration.

front matter, footer, and change log, and these must agree with the index documents; done by hand the check is tedious and error-prone, and the artifact performs it as a structured, repeatable, tracked process. In change logging, every change to a policy or register must be entered in the activity log the standard requires, a purely clerical task that the artifact now performs while the human acts on the result. Across both, the artifact moves the record from creation to verification: the human confirms an assembled record rather than assembling it. The evidence is qualitative and carried by worked examples, a deliberate choice for a single-operator setting where no controlled speed-up is claimed.

5.3. Contradiction-flag analysis

At the case organization, keeping the management system consistent by hand is hard. The more than 30 policies range from three to ten pages each, and a single substantive change can affect several at once. A change to the retention period for logged events, for example, may require edits to the data-governance policy, the logging policy, and the customer-facing user documentation together. Verifying that one change has not broken something elsewhere is exactly the kind of task prone to being done halfway. The flags the artifact raises are where it surfaces these human-made inconsistencies, and analyzing them tests whether its contributions are signal or noise, the relevant reliability question for an assistive layer. The following example illustrates what this contradiction flagging looks like in practice: The company’s public trust center states that its systems are hosted entirely in the EU, which holds for the production system; a separate set of US-based

foundation models is used for product development and specialized customer requests. While ingesting the public website alongside the internal AI-model inventory, the agent semantically linked the “hosted in the EU” claim to those US-based models and flagged the apparent conflict for the officer to reconcile. It had not been asked to check this, as the connection emerged from reading two unrelated sources together. Such a contradiction would not surface from the compliance corpus alone, and catching it before an auditor or customer does is the value the layer adds. This was one of 19 flags the artifact raised across its ingestion, re-ingestion, and lint operations to date, 18 of which the governance officer confirmed as valid concerns in the sources or the derived pages, each citing the specific source location needed to adjudicate it (Table 1). One flag remains open: a legal ambiguity the artifact surfaced over whether the EU AI Act’s general-purpose AI obligations apply to the organization. The question turns on definitions that official sources, including the EU AI Office, have not yet settled, so the flag stays open pending authoritative guidance. False negatives are harder to assess, because a contradiction the artifact misses leaves no trace. To probe recall, we ran a seeding experiment: we introduced 20 inconsistencies by hand, either by editing knowledge base pages or by re-ingesting compliance documents we had altered to contain errors. The artifact caught all 20 during re-ingestion or linting. The sample is small and, more importantly, consists of artificially seeded errors, so the result is best read as an optimistic upper bound.

Table 1. Flags raised in operation, by type and disposition (a), and detection performance combining the operational flags with an artificially seeded-error experiment (b). The single false positive in (b) is one of the cross-source contradiction flags in (a).

(a) Operational flags by type and disposition					(b) Detection performance	
Flag type	Raised	Closed		Open	Measure	Value
		Changed	No change			
Cross-source contradiction	7	6	1	0	Flags raised in operation	19
Legal ambiguity	3	2	0	1	Valid (true positive)	18
Version / ID discrepancy	2	0	2	0	Mistaken (false positive)	1
Outdated content	2	2	0	0	Precision	18/19
Orphan / missing / structural	5	4	1	0	Seeded inconsistencies	20
Total	19	14	4	1	Detected (true positive)	20
					Missed (false negative)	0
					Recall	20/20

5.4. Artifact trade-offs

The artifact carries a standing maintenance and oversight workload. Here, flags must be reviewed and dispositioned and the knowledge base must be kept current as sources change. Adopting it imposes a change-management cost because a governance function must alter its operations. It depends on a specific commercial agentic knowledge base that couples the artifact’s behavior and availability with an external provider. Source ingestion remains partly manual, since preprocessing and upload are deliberately human steps. The use itself risks automation bias as the fluency of the synthesized pages invites over-trust, which the versioned-citation and human-arbitration mechanisms mitigate but do not remove. A focus-group discussion corroborated and extended these trade-offs. The first author presented and demonstrated the artifact to nine practitioners from a professional AI and data-science network in a 60-minute online session, which was transcribed and reviewed to identify recurring concerns and areas of disagreement. The participants discussed comparable experiences and pressed on the artifact’s limits. Three concerns were raised here. Whether the design scales to larger organizations with more documents, how use and maintenance work when several human operators share the knowledge base, and the added workload of keeping the `source` folder current. The first two extend the trade-offs above into questions that the single-site, single-operator setting cannot answer. The third confirms the manual ingestion cost.

6. Discussion

Reading through the hybrid-intelligence frame, the evaluation describes a working division of labor. The agent’s cross-document pattern-finding, surfaced as flags, combines with the officer’s authority and judgment, exercised in arbitration, to produce

governance outcomes neither party reaches alone (Dellermann et al., 2019). The flag precision doubles as a calibrated trust check, high enough to keep the officer acting on the flags while the authority boundary leaves every decision to the human, which holds the collaboration on the use side of Parasuraman and Riley’s misuse axis (Parasuraman & Riley, 1997). **Design principles for agentic knowledge bases in compliance work.** The primary contribution is design knowledge, abstracted as two principles (Gregor et al., 2020) and positioned as an extension of a practitioner pattern to a more demanding problem class (Gregor & Hevner, 2013). *Human authority over agent moderation* vests ownership and approval of the authoritative record in the human, while the agent moderates the derived layer and surfaces issues without authority to override or ratify. The safeguard sits in the architecture: because the agent holds no write access to the authoritative layer, over-reliance cannot translate into an unreviewed change, however fluent the synthesized pages. The principle enacts hybrid intelligence’s task allocation as a boundary the system enforces, and turns the standard caution against automation bias into a structural property rather than a demand on operator discipline (Dellermann et al., 2019; Parasuraman & Riley, 1997). *Traceability* requires that operations are logged and that every derived claim carries a versioned citation to its source, with resolved flags retained as an audit trail, so that the derived layer remains checkable against the record. In terms of knowledge-governance, both express an allocation of decision rights over organizational knowledge (Foss et al., 2010; Grandori, 2001). Existing compliance-automation research automates discrete slices of the lifecycle: obligation extraction from regulatory text (Dal Pont et al., 2025; Galli et al., 2026), technical-documentation review (Sovrano et al., 2025), and obligation-to-test mapping (Zieliński et al., 2026). The agentic knowledge base differs in kind. The agent sustains the connective knowledge layer under an architecture that keeps the

authoritative record human-owned. Its novelty is the maintained, citable substrate rather than a further point of capability. **A shifting feasibility frontier and the case for compliance automation.** The second contribution is reflective. A layered system operating over a live management-system corpus would have been economically out of reach for a single governance officer a few years ago. This feasibility shift matters because the systems under governance obligations are increasingly built, tested, and deployed with substantial agent involvement, and manual governance falls behind within development cycles. When the compliance record no longer describes the system as it actually exists, the organization holds symbolic compliance while the operational reality diverges. The same agentic capabilities that created this pace gap can close it. The artifact repurposes the agent’s capacity for structured knowledge work to keep governance knowledge current at development velocity. The two design principles ensure that this does not trade compliance substance for compliance speed. Human authority over agent moderation makes it architecturally impossible for the agent to alter the authoritative record. Traceability keeps every derived claim checkable against its source. The automation-bias literature warns that human oversight can decay into rubber-stamping under time pressure and agent fluency (Li et al., 2022; Parasuraman & Riley, 1997) for which the architectural separation is this study’s response. The agent handles the pace while the human retains the authority that gives compliance its legitimacy. As agentic coding workflows mature, the agents building AI systems will need access to structured, current governance knowledge to ensure that the systems they produce are safe and compliant by construction. The agentic knowledge base is an infrastructure for that integration as a citable, auditable layer of organizational compliance knowledge, accessible to humans and agents alike. Realizing this at scale remains beyond what a single-site study can demonstrate, but the structural need is immediate. Beyond this case, the architecture enforces human authority but not the vigilance that keeps oversight meaningful, which each adopter must sustain deliberately. Adoption also reshapes the governance function: routines for change logging, review, and audit preparation shift from producing the record to verifying an agent-assembled one, and shared use requires explicit decision rights which the role-based access and approval workflows of the next cycle would formalize. These are standing change-management and oversight costs any adopter must absorb, and building calibrated trust in the system takes time (Lee & See, 2004).

Table 2. Candidate additions to the artifact for the next design cycle. These are design projections, not evaluated results.

What it adds	Why
Version control and interaction logs. Git-versioned corpus; each state and use recorded	History, recovery, and a built-in audit trail
Approval workflow. Agent changes enter a pull-request-style review	Logged human approval for agent suggested changes
Autonomous upkeep. Scheduled checks for consistency and ingesting new/updated information	Drift caught continuously, not only when checked
Page-level tagging. Knowledge pages tagged for role based permission and framework	Scoped access and projection onto the audited standard
Specialised skills. Reusable workflows, e.g. for audit prep, review, and employee onboarding	Consistent, callable routines for humans and agents

7. Toward the Next Design Cycle

Design science treats design as iterative, with each cycle building and evaluating the artifact and the evaluation guiding the cycle that follows (Hevner, 2007). This paper reported two cycles. The second was summative-leaning, judging the mature artifact in use, yet it also surfaced formative insights into where the artifact falls short. We develop those insights here as a third cycle of design plans, distinct from the study’s evaluated results. The most useful additions align the artifact with established software practices. Version control using Git allows for a full history and changes can be rolled back. Approval moves to the pull-request model the developers use for code, so review and sign-off run in a format they already trust. Table 2 lists these and the further additions the cycle envisages.

Taken together, these additions turn the artifact from a single-employee tool into shared infrastructure that people, agents, and auditors can all rely on. Figure 2 shows how this plays out. Team members query it on what a policy permits and report changes it should record. Agents elsewhere in the company consult it when product, quality, or operations work meets a compliance constraint, so the compliance corpus becomes live guidance during development. In an agentic business process, the agent could also approve or monitor defined steps, acting as an assurance checkpoint within the workflow (Vu et al., 2025). An external auditor certifies the proposed governance system. A read-only access exposes the agent’s logs and its exchanges with other systems. These show the defined policies being applied in daily operation, enabling audits to verify meaningful governance processes.

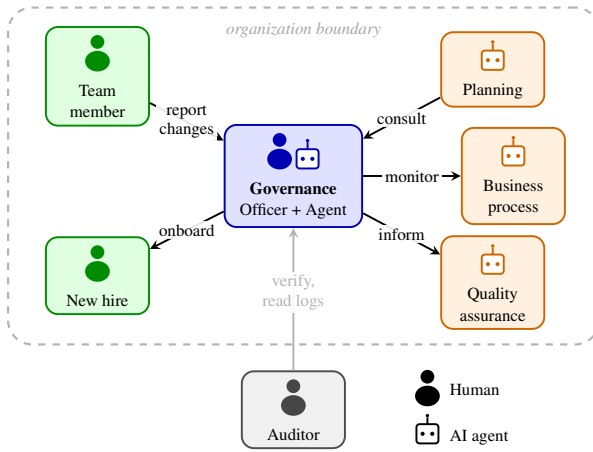


Figure 2. Internal and external actors with interactions envisaged for the next design cycle.

8. Limitations

The study is single-site, and the insider position of the first author is its main risk to validity, bounded but not removed by the independent reviews reported in Section 3. The efficiency evidence is qualitative and carried by worked examples, with no controlled baseline or quantified speed-up, a deliberate fit for a single-operator setting. The cross-standard transfer holds only within one management-system family, since ISO/IEC 42001 and ISO/IEC 27001 share a common structure. The two design principles are stated at a level meant to hold beyond ISO management systems, including direct EU AI Act obligations, but that reach is argued rather than tested here. Finally, the feasibility finding carries a further limit, as the build required the first author’s combined domain and technical fluency, leaving its reproducibility by other practitioners open.

9. Conclusion

This paper asked how an agentic knowledge base can be designed to support auditable, traceable AI governance in a resource-constrained organization that meets compliance standards. We designed, demonstrated, and evaluated such an artifact within a single ISO-certified AI Startup across two management system standards. Its built on a two-layer architecture, with a human-authoritative source layer paired with an agent-moderated knowledge layer. The evaluation suggests the artifact met its objectives as it reduced administrative effort on tasks such as version checks and change logging, shifted the human role from assembling to verifying outcomes, achieved high precision and recall in its contradiction-flag analysis. Here, we

abstracted two design principles, human authority over agent moderation and traceability, the second realized through versioned citations and a retained audit trail. Together they position the agent as a moderator and advisor without authority over the governance record. We further offer a reflective finding on feasibility and compliance automation. AI-assisted development outpaces manual governance, and compliance that cannot keep pace with the systems it governs becomes symbolic. The same agentic capabilities that created this gap prove sufficient to close it: a single governance officer can now build and operate a layered knowledge base over a live management-system corpus, with the agent handling the pace while the human retains authority over the compliance record.

Generative AI Usage Statement. Generative AI tools were used for the preparation of this manuscript. Claude assisted with grammar and style editing, and with formatting of figures and tables. All AI-generated suggestions were critically evaluated, and the authors retain full responsibility for the originality, accuracy, and integrity of all content in this manuscript.

References

- Axelsen, H., Licht, V., & Damsgaard, J. (2025). Agentic AI for financial crime compliance. *arXiv preprint arXiv:2509.13137*.
- Cors, M. S., & Thiébaud, R. (2025). Artificial intelligence and the impact of the EU AI Act in business organizations. *AI Magazine*, 46(4).
- Dal Pont, T., Galli, F., Sartor, G., & Contissa, G. (2025). “lost in EU regulation? don’t worry, AI found the obligation” extracting and representing legal obligations in the GDPR the DSA and the AI Act. *Proceedings of the Twentieth International Conference on Artificial Intelligence and Law*, 129–138.
- Dellermann, D., Ebel, P., Söllner, M., & Leimeister, J. M. (2019). Hybrid intelligence. *Business & information systems engineering*, 61(5), 637–643.
- Edge, D., Trinh, H., Cheng, N., Bradley, J., Chao, A., Mody, A., Truitt, S., Metropolitansky, D., Ness, R. O., & Larson, J. (2024). From local to global: A graph RAG approach to query-focused summarization. *arXiv preprint arXiv:2404.16130*.
- Foss, N. J., Husted, K., & Michailova, S. (2010). Governing knowledge sharing in organizations: Levels of analysis, governance

- mechanisms, and research directions. *Journal of Management studies*, 47(3), 455–482.
- Galli, F., Dal Pont, T. R., Sartor, G., & Contissa, G. (2026). Approaching the AI Act... with AI: LLMs and knowledge graphs to extract and analyse obligations. *Computer Law & Security Review*, 60, 106230.
- Governatori, G. (2015). The rigorous approach to process compliance. *2015 IEEE 19th International Enterprise Distributed Object Computing Workshop*, 33–40.
- Grandori, A. (2001). Neither hierarchy nor identity: Knowledge-governance mechanisms and the theory of the firm. *Journal of management and Governance*, 5(3), 381–399.
- Gregor, S., Chandra Kruse, L., & Seidel, S. (2020). Research perspectives: The anatomy of a design principle. *Journal of the Association for Information Systems*, 21(6), 2.
- Gregor, S., & Hevner, A. R. (2013). Positioning and presenting design science research for maximum impact. *MIS quarterly*, 37(2), 337–355.
- Hevner, A. R. (2007). A three cycle view of design science research. *Scandinavian journal of information systems*, 19(2), 4.
- Jiang, Y., Shao, Y., Ma, D., Semnani, S., & Lam, M. (2024). Into the unknown unknowns: Engaged human learning through participation in language model agent conversations. *Proceedings of the 2024 Conference on Empirical Methods in Natural Language Processing*, 9917–9955.
- Karpathy, A. (2026, April). LLM wiki [Idea file published as a GitHub Gist on 4 April 2026.]. <https://gist.github.com/karpathy/442a6bf555914893e9891c11519de94f>
- Lee, J. D., & See, K. A. (2004). Trust in automation: Designing for appropriate reliance. *Human factors*, 46(1), 50–80.
- Li, Z. S., Werner, C., Ernst, N., & Damian, D. (2022). Towards privacy compliance: A design science study in a small organization. *Information and Software Technology*, 146, 106868.
- Mäntymäki, M., Minkkinen, M., Birkstedt, T., & Viljanen, M. (2022). Putting AI ethics into practice: The hourglass model of organizational AI governance. *arXiv preprint arXiv:2206.00335*.
- Marino, B., & Lane, N. D. (2026). Computational compliance for AI regulation: Blueprint for a new research domain. *arXiv preprint arXiv:2601.04474*.
- Mittelstadt, B. (2019). Principles alone cannot guarantee ethical AI. *Nature machine intelligence*, 1(11), 501–507.
- O’Sullivan, P., Seppälä, S., & Feller, J. (2026). Towards scaling expertise with generative AI: Design principles for governing AI-mediated knowledge capture and transfer. *Journal of Decision Systems*, 35(1), 2669855.
- Parasuraman, R., & Riley, V. (1997). Humans and automation: Use, misuse, disuse, abuse. *Human factors*, 39(2), 230–253.
- Peffer, K., Tuunanen, T., Rothenberger, M. A., & Chatterjee, S. (2007). A design science research methodology for information systems research. *Journal of management information systems*, 24(3), 45–77.
- Rasmussen, P., Paliychuk, P., Beauvais, T., Ryan, J., & Chalef, D. (2025). Zep: A temporal knowledge graph architecture for agent memory. *arXiv preprint arXiv:2501.13956*.
- Schiff, D., Rakova, B., Ayes, A., Fanti, A., & Lennon, M. (2021). Explaining the principles to practices gap in AI. *IEEE Technology and Society Magazine*, 40(2), 81–94.
- Sovrano, F., Hine, E., Anzolut, S., & Bacchelli, A. (2025). Simplifying software compliance: AI technologies in drafting technical documentation for the AI Act. *Empirical Software Engineering*, 30(4), 91.
- Venable, J., Pries-Heje, J., & Baskerville, R. (2016). FEDS: A framework for evaluation in design science research. *European journal of information systems*, 25(1), 77–89.
- Vu, H., Klievtsova, N., Leopold, H., Rinderle-Ma, S., & Kampik, T. (2025). Agentic business process management: Practitioner perspectives on agent governance in business processes. *International Conference on Business Process Management*, 29–43.
- Zhang, B., & Soh, H. (2024). Extract, define, canonicalize: An LLM-based framework for knowledge graph construction. *Proceedings of the 2024 conference on empirical methods in natural language processing*, 9820–9836.
- Zieliński, P., Roesti, M., Barreto, R., & Tahaei, M. (2026). Operationalizing responsible AI policies with LLMs: An end-to-end monitoring prototype. *Proceedings of the Extended Abstracts of the 2026 CHI Conference on Human Factors in Computing Systems*, 1–15.